

1. Ambito operativo

Per questo laboratorio sono nell'ambito operativo le attività di analisi statica e dinamica del malware *AdwereCleaner*, e il suo eseguibile `AdwereCleaner.exe`.

Nell'analisi statica sono state analizzate le chiamate a funzioni dello stesso eseguibile, o di chiamate a librerie dinamiche (DLL) esterne, definite nello stack di esecuzione tramite il software *PE-Studio* nell'ambiente isolato virtualizzato "FlareVM". Come analisi successiva, ovvero di analisi dinamica, si è analizzato il comportamento del malware nel tempo di esecuzione, o *runtime*, dell'eseguibile nell'ambiente *Sandbox on-cloud ANY.run*, tramite l'analisi dell'esecuzione al collegamento <https://app.any.run/tasks/13c2198d-17bd-4c57-93cf-451681600fff/>.

2. Analisi statica

Nell'analisi statica sono state analizzate le chiamate a funzioni dello stesso eseguibile, o di chiamate a librerie dinamiche (DLL) esterne, definite nello stack di esecuzione tramite il software *PE-Studio* nell'ambiente isolato virtualizzato "FlareVM".

2.1. Analisi generale del campione e identificatori (IoC) del malware

L'analisi statica condotta sull'eseguibile `AdwereCleaner.exe` ne identifica la natura di eseguibile Win32 a 32-bit con interfaccia grafica (GUI). L'analisi del binario ritorna la riconducibilità tramite le seguenti stringhe:

Tipo stringa	Valore
checksum MD5	248AADD395FFA7FFB1670392A9398454
Integrità hash SHA-256	51290129CCCCA38C6E3B4444D0DFB8D848C8F3FC2E5291FC0D219FD642530ADC
imphash	01916D29E1D901784B62ABDC4C2F0C45

L'esito di 52/68 assegnato da VirusTotal indica un punteggio di rilevamento estremamente alto, con 52 ambienti di rilevazione *malware (engine)* su 68 che classificano il file come malevolo. Dal punto di vista dell'architettura software, il file è stato compilato originariamente tramite "*Microsoft Linker 6.0 / Visual Studio 2003*" ed è stato pacchettizzato utilizzando l'installer "*Nullsoft Scriptable Install System*" (NSIS).

2.2. Struttura PE, Entropia e Overlay

Il file ha una dimensione complessiva di 195.400 byte e registra un valore di entropia molto elevato, pari a 7.873 su un massimo teorico di 8. Tale livello di entropia indica in modo inequivocabile la presenza di dati fortemente compressi o cifrati all'interno della struttura *Portable Executable*. L'*entry point* è posizionato all'indirizzo `0x000030E4` nella sezione `.text`, mentre risulta presente la sezione virtualizzata `.ndata`. L'aspetto più rilevante risiede nell'area di *overlay*, che inizia all'offset `0x00012E00` per una dimensione di 110.816 byte ed un'entropia di 7.996.

L'intestazione (*header*) dell'*overlay* rivela la firma testuale `NullsoftInst`, a conferma del fatto che il payload effettivo e i relativi script di installazione sono stipati nel payload comprimibile gestito dallo *stub* NSIS.

2.3. Analisi del certificato e della firma digitale

Nel pannello relativo alla firma digitale è presente un certificato con formato PKCS7 della dimensione di 7.272 byte con numero seriale `5182E5B24A4BCE268960C54B36E71D02`. Il timestamp evidenzia che la firma è stata apposta il 28 marzo 2015, ma il certificato risulta scaduto dal 15 luglio 2015. L'uso di firme digitali scadute o ereditate da vecchie release è una tecnica ricorrente negli installer rogue per eludere i controlli euristici preliminari dei sistemi operativi Windows.

2.4. Importazioni API e librerie Windows

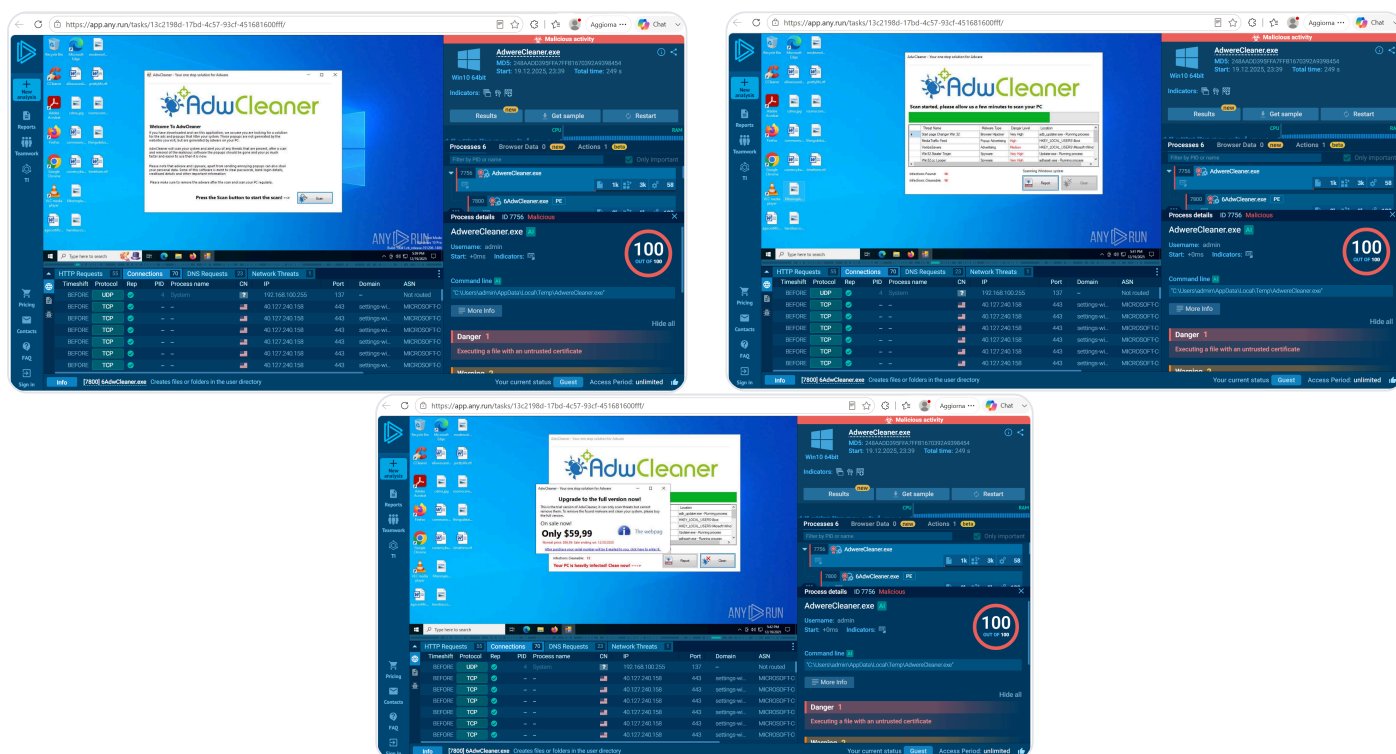
L'analisi delle API importate mostra una dipendenza diretta da funzioni basilari della libreria `kernel32.dll` ed `user32.dll` del sottosistema Win32. Tra i simboli di rilievo figurano `CreateProcessA`, `CopyFileA`, `DeleteFileA` e `CreateDirectoryA` per la gestione ed esecuzione di processi e file nel file system, oltre a `CloseClipboard` ed `EmptyClipboard` per la manipolazione degli appunti di sistema. Non sono state rilevate chiamate native all'infrastruttura `.NET Framework` (come `mscorlib.dll` o routine di runtime CLR), confermando che il binario è un wrapper nativo Win32 e non un assembly gestito C#/VB.NET.

2.5. Manifest e risorse

Il manifest XML integrato identifica l'assembly con il nome `Nullsoft.NSIS.exehead` e descrizione `Nullsoft Install System v3.0a2`. Nell'elemento `trustInfo`, il livello di esecuzione richiesto (`requestedExecutionLevel`) è impostato su `asInvoker` con `uiAccess` disattivato, permettendo all'eseguibile di avviarsi mantenendo i medesimi privilegi del processo genitore senza invocare immediatamente un *prompt User Account Control*, o UAC. La sezione risorse ospita 6 elementi per un peso di 45.255 byte (pari al 23.16% dell'intero file), mentre tra le stringhe si evidenzia l'URL di gestione errori NSIS http://nsis.sf.net/NSIS_Error

3. Analisi dinamica in ambiente *sandbox ANY.run*

Per l'analisi dinamica, ovvero l'analisi dell'esecuzione del campione di malware all'interno di un ambiente controllato ed isolato (sandbox), si è utilizzata la piattaforma di analisi sandbox *ANY.run*.



Schermate dell'ambiente di *sandbox ANY.run*, nelle quali si nota l'interfaccia del malware `AdwCleaner.exe` in tre momenti del processo di ritorno di *malware* fittizi, e la successiva richiesta di acquisto di una chiave seriale d'uso per la rimozione dei malware ritornati

3.1. Tattiche, tecniche e procedure del malware (TTP)

Nell'analisi dinamica dell'eseguibile `AdwCleaner.exe` (eseguibile *NSIS* a 32-bit), si evidenzia un livello di minaccia classificato dalla piattaforma *ANY.run* come attività malevola con l'alto punteggio di rischio pari a 100/100. Il malware impiega tecniche di persistenza configurando meccanismi di avvio automatico (*autostart*) e sfrutta l'esecuzione di processi multipli per distribuire le proprie attività nel sistema.

3.2. Eventi di Rete e Connessioni Command & Control (C2)

- <https://www.vikingwebscanner.com> , con riferimento ASN HETZNER-AS ;
- ocsp.usertrust.com , con riferimento ASN CLOUDFLARENET .

The screenshot displays the AdwareCleaner application interface. The top navigation bar includes icons for Network, Files, CPU, and RAM. The main window is divided into two panes. The left pane, titled 'Network', shows a list of network requests with columns for Timefirst, Protocol, Rep, PID, Process name, CN, IP, Port, Domain, ASN, and Traffic. The right pane, titled 'Malicious activity', shows the results of a scan for 'AdwareCleaner.exe', including the MD5 hash, start time, and total time. Below this, there are sections for 'Processes 6', 'Browser Data 0', and 'Actions 1'. The bottom status bar shows the current CPU usage at 775% and the active process as 'AdwareCleaner.exe'.

Timefirst	Protocol	Rep	PID	Process name	CN	IP	Port	Domain	ASN	Traffic
816 ms	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	200 b / 950 b
9058 ms	TCP	✓	7800	6AdwCleaner.exe		172.64.149.23	80	ocsp.usertrust.com	CLOUDFLARENET	547 b / 969 b
9118 ms	TCP	✓	7800	6AdwCleaner.exe		172.64.149.23	80	ocsp.usertrust.com	CLOUDFLARENET	142 b / 475 b
9124 ms	TCP	✓	7800	6AdwCleaner.exe		104.18.38.233	80	ocsp.usertrust.com	CLOUDFLARENET	539 b / 969 b
9132 ms	TCP	✓	7800	6AdwCleaner.exe		104.18.38.233	80	ocsp.usertrust.com	CLOUDFLARENET	141 b / 475 b
174.94 s	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	811 b / 950 b
174.96 s	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	185 b / 950 b
213.81 s	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	No Data
213.81 s	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	811 b / 950 b
214.91 s	TCP	✓	7800	6AdwCleaner.exe		49.13.77.253	80	www.vikingwebscanner.com	HETZNER-AS	161 b / 950 b

Malicious activity

AdwareCleaner.exe
MD5: 248AA0D39F5F77FB1670392A398454
Start: 19.12.2025, 23:39 Total time: 249 s

Win10 64bit

Indicators: 文件

Results Get sample Restart

CPU RAM

Processes 6 Browser Data 0 Actions 1

Filter by PID or name Only important

775% AdwareCleaner.exe

[illegible]

Schermate dell'ambiente di *sandbox ANY.run*, nelle quali si notano l'elenco delle richieste HTTP e delle risoluzioni DNS svolte dal software malevolo in analisi

3.3. Esiti di SURICATA

L'analisi del traffico mediante il motore di *Network Intrusion Detection System* (NIDS) *Suricata* ha registrato 1 evento nel conteggio complessivo dell'analisi. Il modulo di rilevamento ha operato sulla cattura dei pacchetti di rete (PCAP) generati durante l'esecuzione, lavorando con modalità di raccolta impostata su base oraria.

3.4. Panoramica con matrice MITRE

ID MITRE ATT&CK	Tecnica	Descrizione sinottica
T1012	<i>Query Registry</i>	Interrogazione del registro di sistema
T1082	<i>System Information Discovery</i>	Rilevazione delle informazioni di sistema
T1124	<i>System Time Discovery</i>	Lettura dell'ora di sistema
T1518	<i>Software Discovery</i>	Rilevazione dei software e applicazioni installate
T1547	<i>Boot or Logon Autostart Execution</i>	Esecuzione automatica all'avvio o al logon
T1562	<i>Impair Defenses</i>	Indebolimento o elusione delle difese di sistema
T1614	<i>System Location Discovery</i>	Rilevazione della posizione geografica/lingua di sistema

4. Ipotesi di classificazione del software

In analisi dalle evidenze dell'analisi statica e dinamica, e dalle classificazioni fornite dai principali vendor di sicurezza, il campione viene identificato in modo prevalente con le seguenti classificazioni:

- "*Rogue Antivirus*" o "*FakeAV*", come indicato dagli ambienti di rilevazione *malware*, al momento della redazione del presente report, quali *Microsoft*, *Kaspersky*, *Avast*, *AVG*, *Symantec* e *DrWeb* attraverso definizioni quali *Rogue:Win32/Wadebooc* e *Trojan-FakeAV*, concepito per mostrare falsi avvisi di infezione al fine di trarre in inganno l'utente.
- Hoax*, *Dropper* e *HackTool*, sulla base della struttura malevola dell'eseguibile e della sua funzione di simulazione di minacce o veicolare ulteriori componenti dannosi all'interno del sistema.